

# Privacy and Security Overview

The privacy and security of health information is a core function of the health information (HI) department. Prior to the Health Insurance Portability and Accountability Act (HIPAA), a national regulation governing the privacy and security of health information did not exist. In 2009, the Health Information Technology for Economic and Clinical Health Act (HITECH), under the American Recovery and Reinvestment Act (ARRA) of 2009, created stronger privacy and security requirements for health information. In January 2013, the Omnibus Rule finalized those HITECH updates and also included more strict enforcement rules, as well as breach notification rules. It is imperative that HI professionals understand privacy and security issues related to information systems including electronic health records (EHRs), clinical information systems, and administrative information systems.

## HIPAA Privacy and Security

When the patient's health information was in a paper record, it was more manageable as access was limited to whomever actually had the record. However, with the implementation of the EHR, healthcare professionals can access this information from anywhere, including outside the healthcare organization. The EHR is the primary tool that is used to collect the patient's longitudinal health history. The data that is collected over a period of time is important to understand and bring meaning to the patient's story.

Congress implemented HIPAA in 1996. HIPAA focuses on protecting the privacy and security of protected health information (PHI) that is sent from one organization to another in any format (i.e. paper, electronic, fax etc.) and applies to covered entities including health plans, healthcare providers, healthcare clearinghouses. Health information privacy involves the rights of a person related to their health information. Health information security outlines how to safeguard the information.

According to the U.S. Department of Health and Human Services, "The Office for Civil Rights enforces the HIPAA Privacy Rule, which protects the privacy of individually identifiable health information; the HIPAA Security Rule, which sets national standards for the security of electronic protected health information; and the confidentiality provisions of the Patient Safety Rule, which protect identifiable information being used to analyze patient safety events and improve patient safety" (Office for Civil Rights, Health Information Privacy).

Access the U.S. Department of Health & Human Services to review details about [Health Information Privacy](#).

## Covered Entities and Business Associates

Covered entities and business associates are required to abide by the HIPAA Rules.

The privacy rule portion of HIPAA indicates how PHI can be used and defined, and therefore covered under this rule. Health information that is covered under the HIPAA privacy rule also covers several patient rights related to PHI such as the fact that a patient has the right to inspect, copy, and receive a copy of their medical record. The healthcare organization is responsible to have policies and procedures in place to assure these patient rights are followed when claimed by patients.

The HIPAA security rule outlines the minimum a healthcare organization (that meets the definition of a covered entity) has to do to protect PHI that is electronic. It does not impact PHI that is not electronic such as paper or microfilm. The security rule indicates what an organization needs to do but not how to do it because the options available with technology change so quickly the 'how' will vary by organization and what they are able to do at that time.

Access the U.S. Department of Health & Human Services to read about [Covered Entities and Business Associates](#). Consider the following three questions:

#1

How does the Office of Civil Rights (OCR) enforce the Privacy and Security rules?

#2

What is a covered entity?

#3

What is the *Breach Notification Rule*?

## HIPAA Security Rule

*"The HIPAA security rule has remained unchanged since its implementation more than a decade ago. However, the Health Information Technology for Economic and Clinical Health (HITECH) Act, amended by the Omnibus Rule on January 25, 2013, includes provisions that change several important aspects of the rule. The Omnibus Rule requires the compliance of business associates (BAs) and their subcontractors. It also requires the Office for Civil Rights (OCR) to perform audits that include stiffer penalties for non-compliance. Achieving compliance requires organizations to maintain and implement effective written policies and procedures as well as implement safeguards and controls."*

*The HIPAA Security Rule describes safeguards as the administrative, physical, and technical considerations that an organization must incorporate into its HIPAA security compliance plan. Safeguards include technology, policies and procedures, and sanctions for noncompliance."*

## Notice of Privacy Practices

*"Timely, accurate, and complete health information must be collected, maintained, and made available to members of an individual's healthcare team so that members of the team can accurately diagnose*

*and care for that individual. Most individuals understand and have no objections to this use of their information."*

*"Although consumers trust their caregivers to maintain the privacy of their health information, they often are skeptical about the confidentiality and security of their information when it is maintained electronically or disclosed to others. Increasingly, consumers want to be informed about which information is collected, disclosed and viewed. Additionally, they want some control over how their information is used.*

*Federal rules require providers to notify patients of the full uses, disclosures, and protections of the information they collect. This practice brief outlines the federal requirements for the Notice of Privacy Practices (NPP)."*

## Clinical and Administrative Systems

Moving the patient's health information from paper to electronic has modified the processes and procedures used by HI professionals but not eliminated them. HI continues to manage and oversee the privacy of the patient information in its new electronic format within the various systems it is stored. Because the security of the health information requires a solid understanding of the business practices of the organization and technology, the responsibility often falls to the Information Technology (IT) department. However, HI continues to be involved.

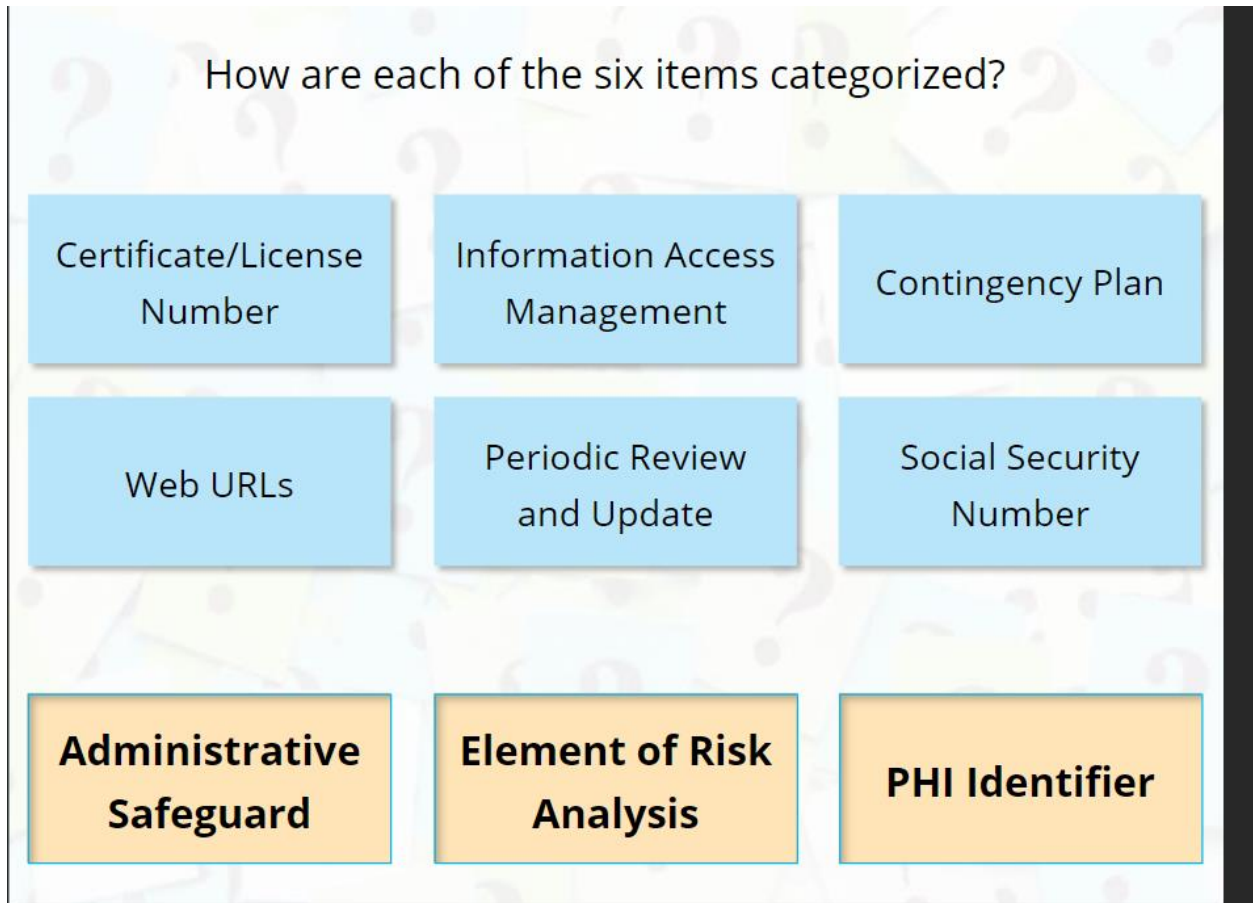
HIPAA defines a designated record set (DRS) as records that contain both financial information and any information about treatment used to make decisions about an individual. An organization needs to define what is included in their designated record set and where it is located. This is especially true in the case of hybrid information systems. "The legal health record (LHR) is an organization's official business record and consists of documents and data elements that may be disclosed in response to legally permissible requests for patient information." (*Introduction to Health Information Privacy & Security*, 2nd ed. AHIMA)

The security rule has five different categories of standards (found in 45 CFR 164.310-164.316):

- Physical safeguards
- Technical safeguards
- Administrative safeguards
- Organizational requirements
- Policies and procedures and documentation requirements

A healthcare organization will decide which of these standards they are able to apply based on several factors such as their size, cost of the security measures, and their technical infrastructure, hardware, and software security abilities. All of the security and privacy rules and nuances apply to EHRs as well as clinical and administrative information systems. HI professionals are involved in different pieces and parts of privacy and security which varies by healthcare organization. At the center of privacy and security is the patient and their information of which the management and protection of continues to be health information's responsibility on behalf of each individual patient.

Access the [U.S. Department of Health & Human Services](https://www.hhs.gov/ohrt/) to review 45 CFR (Code of Federal Regulations) parts 160, 162 and 164 for more information on the federal privacy and security regulations.



## Privacy and Security Compliance

To assure alignment with the Health Insurance Portability and Accountability Act (HIPAA), it is recommended that healthcare organizations have HIPAA privacy and security policies and procedures as well as a collection of metrics such as the number of reportable breaches. Audits and other processes may exist within a healthcare organization as part of their compliance efforts in the area of information and technology system privacy and security. Health information professionals are often involved in many of these areas due to their knowledge and skill set as well as their role in the management of the healthcare information and associated systems. It is also an area for more opportunity to go beyond the traditional health information roles in the ever-changing and evolving world of information technology.

## Access to Health Information

Access is “the ability or the means necessary to read, write, modify or communicate data/information or otherwise use any system resource” ([45 CFR 164.304](#)). Access must be controlled to assure only people or technology programs that need protected health information (PHI) can obtain it and that the access is limited to the minimum necessary information needed to perform their jobs. A healthcare organization needs policies and procedures in place to limit access and assure compliance of their staff. There are different types of access to technology and information systems. An individual has a username and password to gain access into the systems they need to do their job. An organization also has to control access physically to their data center and software. This is usually limited to the information system/technology staff. This type of access control may involve cameras, the use of key cards and even alarm systems to protect the hardware of this area.

HIPAA gives a person the right to access their own PHI. This right allows an individual to review and obtain a copy of PHI that is in their health record. The release and access of an individual's PHI is usually managed by the health information department. Specific policies and procedures are in place related to patient PHI access to cover things such as:

- PHI access request – is it required to be in writing or is verbal acceptable? Does the organization have a specific form to be used?
- Reviewing the PHI – the organization needs to set up a specific time and place with the requestor
- Format of PHI requested needs to be determined – paper/hard-copy, electronic/digital
- PHI - Is it sent to requestor or another person or entity?
- Charges for providing copies – organization needs to establish fees and may include copying and postage

## Auditing and Compliance

“Organizations must develop security audits and related policies and procedures to hold members of the workforce accountable for their actions when accessing electronic protected health information (ePHI) through the electronic health record (EHR). Organizations must perform security audits using audit trails and audit logs that offer a back-end view of system use. Audit trails and logs record key activities, showing system threads of access, modifications, and transactions.” ([AHIMA Practice Brief: Privacy and Security Audits of Electronic Health Information \(2014 update\)](#))

The HIPAA security rule and the Health Information Technology for Economic and Clinical Health (HITECH) Act both require organizations to perform security audits. A multidisciplinary team (including IT, HI and risk management minimally) should be created to develop and implement a security audit process.

There is so much data today in the EHR that what needs to be audited has to be defined in the audit procedures. Focus should be on events that would flag questionable access of confidential ePHI such as:

- Viewing a record of a patient with the same last name or address as the reviewer

- Employee viewing of a record that was involved in a high-profile event in the community (i.e. MVA, attempted homicide)
- Employee viewing of records of terminated employees.

Audits are generally performed when a potential situation is in question regarding access. However, it is a good practice to establish audits on a regular basis (for instance, monthly) on some of the questionable events that have or could occur as well as including random audits of different employees and external entities that have access. Regular audits will help prevent potential issues before they arise. The results of any audits performed, need to be shared with those involved and appropriate management and then education provided to prevent these issues from occurring in the future.

The security rule includes a policy and procedure standard (45 CFT 164.316(a)) and documentation standard (45 CFR 164.316(b)(1)) that require reasonable and appropriate policies and procedures be established and maintained to be in compliance. The standard doesn't specify what the policies and procedures must contain but generally procedures give detailed steps on how the organization will carry out the security rule requirements.

Access the U.S. Department of Health & Human Services to review details about [HIPAA for Professionals](#). Read the 'Guidance' information under Privacy and Security and the 'Health Information Technology' portion under Special Topics. *Note that the HHS website is an invaluable resource to a new HI professional and throughout their career.*

## Breach Management

*"A breach is defined as "the acquisition, access, use, or disclosure of protected health information in a manner [not permitted by the HIPAA Privacy Rule] which compromises the security or privacy of the protected health information" in 45 CFR 164.402. An impermissible use or disclosure of PHI is presumed to be a breach unless the covered entity (CE) or business associate (BA), as applicable, demonstrates based on a risk assessment that there is a low probability the PHI has been compromised. As a result, breach notification is necessary in all situations except those in which the CE or BA, as applicable, demonstrates there is a low probability that the PHI has been compromised."*

## Privacy and Security Audits

*"It would be prohibitive to perform security audits on all data collected. Good-faith efforts to investigate the compliance level of individuals educated on privacy and information security issues can be achieved through a well-planned approach. When determining what to audit, healthcare organizations must identify and define "trigger events," meaning the criteria that will flag questionable access of confidential ePHI and prompt further investigation. Some trigger events will be appropriate, while others will be specific to a department or unit. Once identified, trigger events should be reviewed on a regular basis, such as annually, and updated as necessary."*